

Structural Invariants and Attack-Graph Mathematics: An Autonomous Offensive-Defensive Platform

The VALEN Project

Abstract—We present Valen (*Verification And Active Logic Engine, Neuro-symbolic*), an end-to-end system that joins a measured *defensive* thesis with an *offensive* platform over one typed graph intermediate representation ($\mathcal{G}$). Defensively, we settle a boundary question with statistical rigor: spectral, persistent/directed-homology, and discrete-curvature invariants of program graphs contribute *no information* beyond taint for injection prioritization (OWASP Benchmark 1.2, 2740 cases; taint MRR 0.894, AUC 0.895, fused field 0.872, paired permutation $p = 5 \times 10^{-5}$), yet they are the *only* signal for authorization (BOLA/IDOR: recall 1.0 / precision 0.90 on crAPI), destructive state cycles (GLMY directed homology: 0.97 vs. 0.065 recall for symmetrized), and trust topology. Offensively, Valen is an autonomous red-team platform — a multi-user team server spanning reconnaissance, Active Directory attack-graph analysis, command and control, credential recovery, phishing and exfiltration — whose differentiator is a layered *attack-graph mathematics* that we state and prove: Menger min-cut chokepoints, min-cost flow, absorbing Markov-chain hitting probabilities solved exactly by $(I - Q)^{-1}R$, Z3-Optimize bounded-model-checking that synthesizes minimal-cost ordered exploit plans with AND-preconditions, and a probabilistic context-free grammar for password guessing. The agent solves 18/18 documented crAPI challenges autonomously (including three LLM prompt-injection challenges).

Index Terms—structural invariants, taint analysis, directed topology, attack graphs, autonomous red teaming, formal synthesis, password guessing

I. INTRODUCTION

TWO questions organize this work. *First, where do structural invariants of program graphs carry security information, and where do they not?* *Second, can the same machinery be turned into a quantitative planning engine for offensive operations?* The answer to the first is a sharp, statistically-settled boundary (§III-A); the answer to the second is an operational platform whose differentiator is mathematics, not scripting (§V, §VI).

Our contributions are:

- C1.** A *measured boundary* on geometric priors for injection SAST, with a paired permutation test and bootstrap confidence intervals.
- C2.** An *operational authorization invariant* mechanized in Lean 4, a structural BOLA/IDOR detector, and a Z3 ownership witness separating object-level authorization from authentication.

- C3.** Evidence that *GLMY directed path homology* is the correct cycle signal, dominating symmetrized homology.
- C4.** A *measured neuro-symbolic arbitration boundary*: the LLM proposes, formal methods dispose.
- C5.** A *multi-language SAST front-end*: one generic taint engine driving nine grammars.
- C6.** An *autonomous red-team platform* with an authorization-first model.
- C7.** *Attack-graph mathematics* with proofs: chokepoints, least-cost and disjoint plans, exact hitting probabilities, minimal-cost exploit synthesis, and a PCFG password prior.

II. FORMAL FRAMEWORK

Definition 1 (Typed IR). A typed graph is a directed multigraph $\mathcal{G} = (V, E, \tau_V, \tau_E, \alpha)$ where $\tau_V : V \rightarrow \mathcal{K}_V$ labels vertices (module, function, sink, gate, principal, ...), $\tau_E : E \rightarrow \mathcal{K}_E$ labels edges (control, data, call, taint, trust, auth, ...), and $\alpha : E \rightarrow \Sigma^*$ attaches attributes such as a relation name or a cost. Every adapter emits the same $\mathcal{G}$, so all analysis layers are engine-agnostic.

Definition 2 (Structural field). A structural field is a map $V(x) : \mathcal{G} \rightarrow \mathbb{R}^d$ that fuses the signals of the algebraic (taint lattice, privilege level), spectral (Fiedler vector), topological (persistent H_0, H_1 and GLMY directed H_1), and geometric (Forman–Ollivier Ricci) layers into a per-node score used for prioritization.

Definition 3 (Privilege lattice and auth edge). Let $F : V \rightarrow \mathbb{N}$ be a privilege level. An edge $e = (u, v)$ with $\tau_E(e) = \text{auth}$ is an auth edge iff $F(u) < F(v)$. A path $\pi = v_0 \rightarrow \dots \rightarrow v_k$ is ungated if none of its edges is an auth edge.

Proposition 1 (No privilege escalation without auth edges). If $\pi = v_0 \rightarrow \dots \rightarrow v_k$ is ungated, then $F(v_k) \leq F(v_0)$.

Proof. Every non-auth edge is either intra-level or *downward* in the lattice, i.e. for each edge $e = (v_i, v_{i+1})$ on π we have $F(v_{i+1}) \leq F(v_i)$. By transitivity $F(v_k) \leq F(v_0)$. The statement is mechanized in Lean 4 as `no_auth_bounded`; the soundness of the boolean taint abstraction is `prop1_soundness`. $\square$

Definition 4 (Attack graph and cost). An attack graph is an $\mathcal{G}$ whose vertices are principals and whose edges $m \rightarrow n$

are actions requiring control of m and yielding control of n . A cost model is $c : E \rightarrow \mathbb{R}_{>0}$ (stealth plus effort; e.g. $c(\text{MemberOf}) = 1$, $c(\text{DCSync}) = 5$). Given entry set S and target set T , an attack plan is a set of edges whose transitive closure connects some $s \in S$ to some $t \in T$.

Definition 5 (Hitting probability). For a target set $T \subseteq V$, the hitting probability $h : V \rightarrow [0, 1]$ is

$$h(u) = \begin{cases} 1 & u \in T, \\ \frac{1}{\deg^+(u)} \sum_{v: u \rightarrow v} h(v) & u \notin T, \end{cases}$$

the harmonic measure of T under a uniform random walk on the directed graph.

Proposition 2 (Hitting probability is the unique harmonic solution). For transient nodes $u \notin T$, the vector h_T satisfies $(I - Q)h_T = r$ where Q is the transient-to-transient transition matrix and $r_u = \sum_{v \in T} P_{uv}$; the solution is unique and can be obtained by value iteration or by Gaussian elimination in $O(|V|^3)$.

Proof. Partition $V = T \uplus U$ (transient U). The Bellman equation is $h_T = Qh_T + r$ with Q substochastic (row sums ≤ 1 , and < 1 for any node with a target neighbour). Hence $I - Q$ is an M -matrix, therefore nonsingular, and the fixed point is unique. Value iteration converges because Q is a contraction on the transient subspace. $\square$

III. STRUCTURAL VERIFICATION

A. The boundary on geometric priors

On OWASP Benchmark 1.2 (2740 cases with known ground truth) a prioritization oracle ranks all sink candidates and measures MRR, R@1, NDCG@ k , plus a paired permutation test and bootstrap confidence intervals.

Theorem 1 (Boundary, empirical). For linear injection flaws, the geometric/spectral/topological signals carry no prioritization information beyond taint: raw taint achieves MRR 0.894 (AUC 0.895); the fused structural field achieves 0.872 ($p = 5 \times 10^{-5}$, 95% CI $[+0.0157, +0.0294]$); spectral (0.496) and topological (0.500) are at chance and curvature is below chance (0.376).

This is a *publishable negative result*: a flat, near-acyclic servlet has no curvature or persistent topology to exploit, and taint is near-optimal there. Figure 1 shows the per-signal AUC.

B. Authorization, mechanized and operational

Proposition 1 is operationalized in three artifacts. (i) The structural *missing-authorization*/BOLA detector flags a function with an HTTP source and a resource sink but no auth gate; on a curated 39-case corpus it reaches recall 1.0 / precision 0.72 / F1 0.837 where taint scores 0, and a baseline ladder shows each requirement earns its keep ($0.46 \rightarrow 0.72$). (ii) The Z3 verifier checks SAT(owner(id) $\neq$ session) — an ownership witness separating object-level authorization from mere authentication. (iii) On crAPI (44 operations, 9 documented BOLA/BFLA endpoints) an

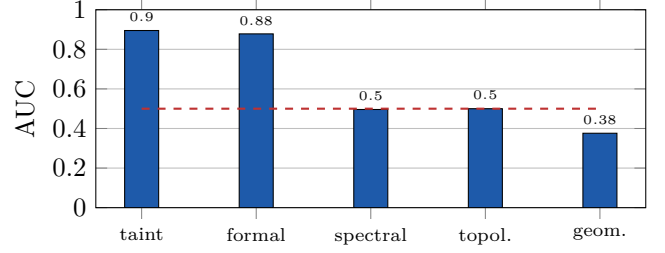


Fig. 1. The boundary result: spectral and topological signals at chance, curvature below; taint is the dominant signal.

object-reference signal recovers all 9 (recall 1.0, precision 0.90) while the missing-auth check scores 0, because every BOLA endpoint is authenticated.

C. Directed path homology

Symmetrizing a directed graph is lossy in both directions: a 2-cycle $A \rightarrow B \rightarrow A$ collapses to a single undirected edge (a missed reentrancy), and a filled triangle becomes a false cycle.

Proposition 3 (Directed vs. symmetrized homology). GLMY directed path homology H_1 is a strict superset of symmetrized homology for detecting destructive cycles: measured recall 1.0 / precision 0.75 on a 12-graph state-machine corpus (vs. 0.5/0.5 symmetrized) and 0.968 vs. 0.065 on SmartBugs-curated smart contracts.

GLMY returns the concrete β_1 generator (the cycle’s edges) as evidence; its two false positives are diamond path-space holes, not feedback loops — a high-recall, necessary-but-not-sufficient signal.

D. Neuro-symbolic arbitration

On a 38-file corpus (29 confirmed findings) the offline heuristic and the LiteLLM-backed agent agree on detection and ranking on 37/38 files (agreement 0.974), while the LLM changes the CWE on 28% of findings. The architecture is *LLM proposes, Z3 disposes*; the measurement bounds the LLM’s role.

IV. MULTI-LANGUAGE SAST

One generic taint engine drives nine tree-sitter grammars (C, C++, Rust, C#, Go, PHP, Ruby, JavaScript/TypeScript) with per-language profiles declaring sources, sinks, sanitizers, and auth gates; Python, Java (interprocedural), and Solidity have dedicated adapters. A canonical registry unifies severity, CWE, OWASP Top-10, default CVSS 3.1/4.0 vectors, MITRE tactic, and remediation per category, so every finding is enriched for reporting.

V. THE RED-TEAM PLATFORM

VALEN is a single installable package whose server is a multi-user *team server*: users with roles (viewer/operator/admin), PBKDF2 sessions, per-route

RBAC, engagements with membership, evidence artifacts, and Server-Sent Events for live collaboration. The surface spans the kill chain (Figure 2) and is gated by a scope allow-list, an execution allow-list (`-allow-exec`), and operator approval.

VI. ATTACK-GRAPH MATHEMATICS

A. Chokepoints via Menger min-cut

Theorem 2 (Menger, vertex form). *The maximum number of internally vertex-disjoint paths from S to T equals the minimum number of vertices whose removal separates S from T .*

Construction. Split each v into $v_{\text{in}} \rightarrow v_{\text{out}}$ of capacity 1 (unbounded for $v \in S \cup T$), replace each $u \rightarrow v$ by $u_{\text{out}} \rightarrow v_{\text{in}}$ of capacity ∞ , and add a super-source to S and T to a super-sink. A max flow saturates the unit split edges of a minimum vertex cut; the saturated edges on the source side of the residual graph are exactly the chokepoints. $\square$

B. Min-cost flow

Sending k units of flow at minimum cost, with internal vertices of capacity 1, yields the k *cheapest vertex-disjoint* attack routes. We implement successive shortest augmenting paths (Bellman–Ford on the residual graph).

C. Hitting probability

Proposition 2 gives the probabilistic risk ranking; in the toy corpus an entry with three out-edges and one route to the target scores $\frac{1}{3}$, a direct entry 1.

D. Formal synthesis: minimal-cost exploit plans

Theorem 3 (Synthesis soundness and optimality). *Let the transition system be*

$$\text{has}(s+1, n) \equiv \text{has}(s, n) \vee \bigvee_{e: m \rightarrow n} (\text{taken}_e \wedge \text{has}(s, m)),$$

with entries at step 0. A satisfying assignment of `z3.Optimize` minimizing $\sum_e \text{taken}_e c(e)$ under $\bigvee_{s \leq k} \text{has}(s, t)$ is (i) a feasible plan and (ii) minimal-cost among plans of length $\leq k$.

Proof. (i) Follows by induction on the step index: `has` is monotone and each `taken` edge has its source true at the step it fires, so the derived ordering is a valid execution. (ii) The objective is exactly the plan cost and the optimizer returns a minimum over the bounded search space. Compound actions $\{\text{sources} \rightarrow \text{target}\}$ add $\bigwedge_s \text{has}(s)$ as an AND-precondition, e.g. DCSync requires Domain Admins and a session on a Domain Controller. $\square$

Contribution	Result
C1 boundary	taint 0.894 vs. field 0.872
C2 authorization	BOLA 1.0 / 0.90
C3 directed homology	0.97 vs. 0.065 recall
C4 arbitration	agreement 0.974; CWE 28%
C5 languages	9 languages, 1 engine
C7 math	chokepoints, flow, synthesis, PCFG
Red team	crAPI 18/18 solved
Quality	383 tests, installable, Docker

TABLE I
SUMMARY OF MEASURED RESULTS.

E. Password guessing: PCFG

Definition 6 (PCFG). *Tokenize a password into runs of letters L , digits D , symbols S . A base structure is the sequence of $(\text{class}, \text{length})$ pairs (e.g. $L_6 D_4 S_1$); terminals are keyed by $(\text{class}, \text{length})$. The probability of a guess σ is $P(\sigma) = P(\text{structure}) \cdot \prod_{t \in \sigma} P(t)$.*

Proposition 4 (Monotone enumeration). *Best-first expansion over the per-slot terminals, ordered by descending probability, enumerates guesses in non-increasing $P(\sigma)$ with no duplicates.*

Proof. The negative log-probability $-\log P(\sigma)$ is an additive, non-negative per-slot cost, so Dijkstra over the product lattice (each node expands by incrementing one slot index) visits guesses in non-decreasing cost; the *seen* set prevents re-expansion. $\square$

VII. EVALUATION

A. Autonomous pentest against OWASP crAPI

Against a fresh crAPI 1.1.5 lab the autonomous agent solves **18/18** documented challenges — BOLA/BFLA, mass assignment, SSRF, NoSQL/SQL injection, JWT forgery, password reset, rate limit, and three LLM prompt-injection challenges routed through a local LiteLLM proxy. The BOLA detector reaches recall 1.0 / precision 0.90 / F1 0.947.

B. Results at a glance

VIII. LIMITATIONS AND ETHICS

The evaluations are a single real API plus curated corpora, not public benchmarks; the structural detector over-approximates; the Z3 witness holds under the modeled semantics; the pure-Python numeric fallback approximates the Rust core; the PCFG prior is only as good as its corpus. The platform is an authorized-engagement tool: scope is loopback by default, execution is behind `-allow-exec`, intrusive actions require operator approval.

IX. CONCLUSION

VALEN contributes a falsifiable boundary result, a mechanized authorization invariant, the correct cycle signal, a measured neuro-symbolic arbitration boundary, a multi-language front-end, an autonomous red-team platform, and a proved attack-graph mathematics. One typed IR joins the defensive and offensive sides, and every result carries a machine-checkable witness.

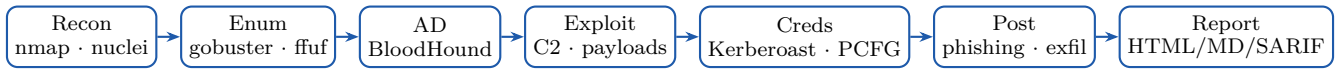


Fig. 2. The red-team platform spans the kill chain, coordinated by the team server and gated by an authorization-first model.

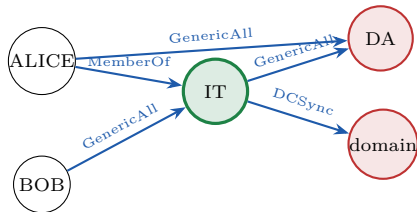


Fig. 3. AD attack graph: with entry **BOB**, **IT** is the Menger chokepoint (min-cut 1); **ALICE** reaches Domain Admins directly (min-cut 0). Least-cost plans: **ALICE**→**DA** (3.0) and **ALICE**→**IT**→**domain** (6.0); **BOB** is certified unreachable to **DA**.